HO TECHNICAL UNIVERSITY

IT Audit Overview

Akwasi Asiedu, CISA

What will be covered?

- Overview of IT audit function
- Description of the work of IT Auditors & skills needed
- Explanation of how to become an IT Auditor
- Description of the structure of IT Audits
- Discussion of IT audit's relationship with accounting and financial audit
- Professional IT Auditors Organizations

Did you know???

- "The need for IT Auditors far outstrips the supply of **qualified candidates**"
- IT Auditors are in demand, but their work is interesting and challenging
- IT Auditors evaluate an organizational entity's IS (Info. Technologies, data and information, and systems of communication)
- Evaluation includes studying documents, interviewing people, entering/manipulating data in a computer.
- IT Auditors do the above because business processes use IT to function and IT is integral to an enterprise's viability

Impact of IT on Organizations

- IT is important in all kinds of organizations
- IT also influences organizational risks and controls.
- IT creates opportunities, but these opportunities bring risks
- E.g., the ability to transmit document electronically to customers & vendors allows improving efficiency in the supply chain; but it (electronic communication systems) also poses new risk

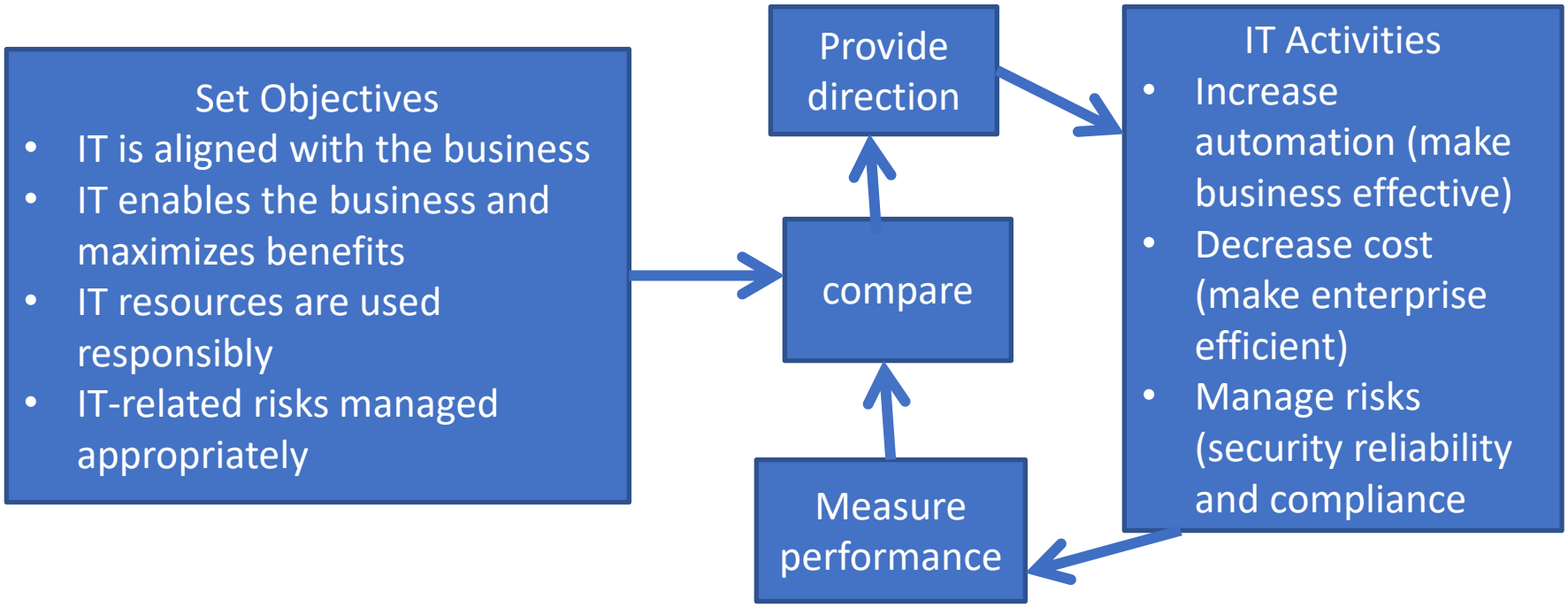
IT Governance

- A process for controlling organization's information technology resources (systems and technology).
- An organization's management and owners (board of directors) are responsible for governing enterprise and IT.
- Enterprise governance – process of setting and implementing corporate strategy, making sure that the organization achieves its objectives efficiently, and manage risks.

- The objectives of IT governance are to set strategies for IT so that it is aligned closely with organizational goals, and to use IT for maximum opportunity, but minimum risk.
- Two parts of IT Governance;
  - concerns the use of IT to promote an organization's objectives and enable business processes;
  - involves managing and controlling IT-related risks

IT Governance - continued

- It begins with
  - The development of IT Governance plan (set the strategic purposes of IT acquisition and deployment or use)
  - It is on on-going process, management needs to regularly evaluate and update plans


Set Objectives
IT is aligned with the business
IT enables the business and maximizes benefits
IT resources are used responsibly
IT-related risks managed appropriately
compare
Provide direction
IT Activities
Increase automation (make business effective)
Decrease cost (make enterprise efficient)
Manage risks (security reliability and compliance
Measure performance

IT Governance - continued

- ISACA established the IT Governance Institute (1998) – to clarify and provide guidance on current and future issues pertaining to IT governance, control and assurance.
- It developed CobiT (Control Objectives of Information and Related Technology, 3rd Edition) and COEG (Control Objectives for Enterprise Governance)
- CobiT provides guidance on IT governance – providing the structure that links IT processes, IT resources and information to enterprise strategies and objectives.
- CobiT also includes an IT Governance Management Guidelines – identifies critical success factors, key goal and performance indicators, matured model for IT governance.
- It is a guideline that allows management to use in evaluating performance with regards to IT

IT and Transaction Processing

- One of the concern in IT Governance is controlling IT risks. This is important in enterprises as they use IT to process data about ongoing transaction or activities.
- Business and other organizational entities are involved in and affected in many ways. IS collects data about all.
- A computerized IS may increase risks and decrease others. Or IT can reduce risks due to human error. How is it possible?

- Scenario 1 – salesclerk manually record data about sale of the day; entered the wrong inventory code. IT can reduce this risk. But, if database admin accidently mismatch the inventory item and its code, then every sale of that inventory item will be recorded incorrectly.

The Work of IT Auditor

- IT Auditor exists as long as IT exists.
- They ensure IT governance, and to do so, they assess IT risks and implement/monitor the controls over those risks.
- Roles and level of expertise varies, might be internal/external auditor.
- They will provide assurance or give comfort about anything related to information systems.
- Evaluating controls over specific applications – analyze risks & controls over applications

The Work of IT Auditor - continued

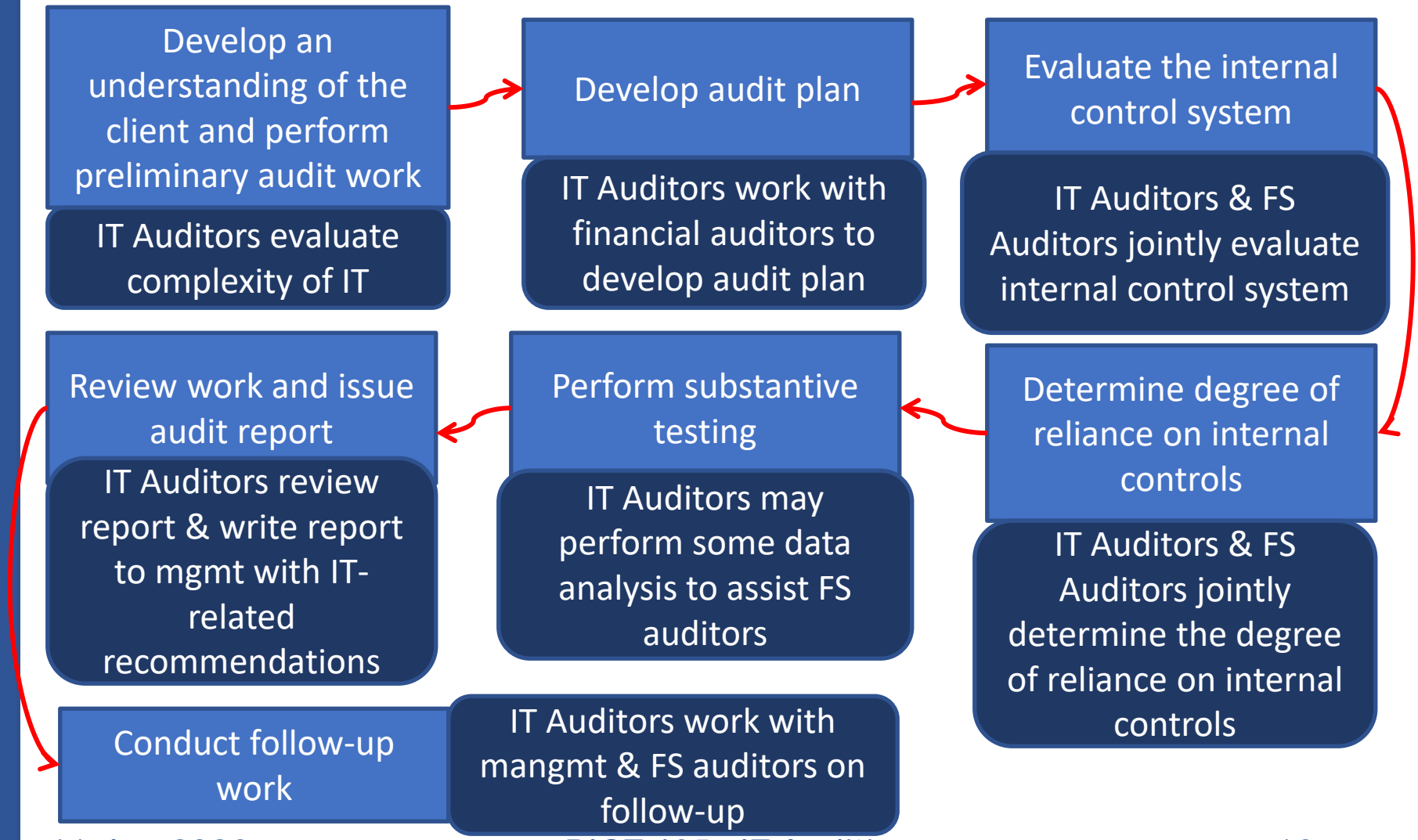
- Provide assurance over specific processes – agreed upon procedures only; client and IT auditor determine the scope of assurance required
- Provide third-party assurance – evaluate the risks and controls over third party's IS and provide assurance to others
- Penetration testing – trying to gain access to info resources in order to discover security weaknesses
- Supporting the financial audit – evaluate IT risks and controls that may affect the reliability of financial reporting system

- Searching for IT-based fraud – to help investigate computer records in fraud investigations

Relationship between Financial and IT Audits

- The objective of a financial statement audit is to ensure that the organization's public financial statements are presented in accordance with generally accepted accounting principles (GAAP). Thus, FS Auditors analyze organization's internal control system to assess the degree which it appears to be operating effectively.
- As computer technology is increasingly relied for processing transactions and reporting information, it is difficult for FS auditors to ignore IT in their audits. Thus, there is a need to evaluate information systems as part of financial audit.

Relationship between Financial and IT Audits



IT Audit Skills

- To become an IT Auditor, you need training and education (at least a bachelor's degree)
- Other than that, you need special certifications or licenses (e.g., Certified Public Accountant – CPA, Certified Fraud Examiner – CFE, Certified Internal Auditor – CIA, Certified Information Systems Auditor - CISA
- Skills required from IT Auditor;

Technical

Business

Personal

Technical Skills

- IT Auditors requires specialized technology skills – different platforms, OS, software applications, network security, ERP systems
- Let say that the IT Auditor is auditing an OS, he/she will have a guide – description of specific features of that OS and steps to follow in extracting data and testing controls
- IT Auditors must have the interest of learning and updating themselves with technical topics as IT changes constantly.

Personal Skills

- Personal Skills – communication skills
- IT Auditors must write and present reports. They frequently make presentations to internal/external clients
- Thus, written and oral communication skills are crucial
- Personal skills – Interpersonal and teamwork
- Rarely, IT Auditors do their jobs in isolation. They need support from other auditors and cooperation from those they are auditing

- IT Auditors must have good interpersonal skills to overcome negative bias of others towards auditors

Business Skills

- Business skills – must understand business processes (financial, distribution, HR, manufacturing)
- IT Auditors will evaluate the IT used by business organizations to support their processes.
- Other skills – financial processes, accounting, marketing skills and decision sciences

Professional IT Auditor Organizations and Certifications

- IT Auditors may choose the many professional organizations to belong to.
- These organizations issue certifications to their members who meet the various service and knowledge requirements.
- Among the many professional organizations available are;
  - ISACA – Information Systems Audit and Control Association
  - IIA – Institute of Internal Auditors

- ACFE – Association of Certified Fraud Examiners
- AICPA – American Institute of Certified Public Accountants

ISACA – Information Systems Audit and Control Association

- Founded in 1969
- The largest professional organization of IT Auditors
- It has more than 25000 members over 100 countries, and has certified more than 29000 IT Auditors
- ISACA has its research unit – the Information Systems Audit and Control Foundation that conduct research and issues publications that guide IT audit professionals.

- ISACA has it IT Governance Institute, K-Net – knowledge network repository of information about IT Governance, control and assurance
- Certified Information Systems Auditor (CISA) designation is highly valued for IT Auditors. A CISA must successfully complete an examination (administered annually), meet professional experience requirements, abide the group's Code of Professional Ethics, and meet continuing education requirements

CISA

- CISA examination test knowledge in 5 technical areas
- You need at least 5 years' of experience in IT Auditing, control, or security to apply for the CISA.
- CISA professionals must agree to a code of professional ethics, abide to ISACA's IS Auditing Standards, complete 20 contact hours of continuing education each year and 120 contact hours in a 3-year period in order to maintain certification
- Besides CISA, CISM – Certified Information Security Manager is another credential for non-audit security professionals

IIA – Institute of Internal Auditors

- Established in 1941 – international organization of internal auditing professionals
- It produces a journal, hosts professional meetings and educational seminars, conducts research through IIA Research Foundation, issues the Certified Internal Auditor (CIA) credential along with certifications in control self-assessment, government auditing and financial services auditing.
- It promotes the practices of internal auditing through quality assurance and the issuance of standards, guidelines and best practices.

- It is one of the primary professional organization that serve accountants in their various roles. The membership is made up of internal auditors.

CIA

- IT Auditor may be external auditor or a member of the organization's internal audit staffs.
- Internal Auditor may choose to be certified as CISA or CPA. And, they may also become a Certified Internal Auditor (CIA)
- CIA requires a bachelor's degree or meet international standards, provide a character reference, have 24-months of internal audit/equivalent experience, and pass the CIA-exam
- CIA must agree to abide to professional code of ethics, complete 80 hours of continuing professional education (CPE) in every 2-year period.

- CIA exam conducted twice per-year covers Professional Practices Framework (internal audit process, internal audit skills, management control and IT, audit environment) & IT (IS strategies, policies and procedures; hardware, platforms, networks & telecommunications; data processing; system development, acquisition & maintenance; IS security & contingency planning)
- Internal auditors involved in assessing their organization's IT risks and controls – provide oversight for security activities and ensure appropriate resources are directed toward controlling IT risks

ACFE – Association of Certified Fraud Examiners

- ACFE issues CFE (Certified Fraud Examiner) – professionals who specialize in auditing for fraud.
- CFE is based on point system. Points are awarded for higher education and professional experiences (directly in fraud examination or related area – accounting, criminology, sociology, fraud investigation, loss prevention, legal fields)
- Must pass exam administered by ACFE (500 objective questions, computer-based; areas covered – fraudulent financial transactions, fraud investigations, legal elements of fraud, criminology, ethics. Does not cover IT) and agree to abide to organization's Code of Ethics and Bylaws

AICPA – American Institute of Certified Public Accountants

- Offers CPA (Certified Public Accountant) license
- It has a membership of 350,000 accounting professionals
- Public companies must have their financial statements audited by CPAs. CPAs will look into all aspects of accounting (tax, consulting, IT auditing). CPA is a good foundation to IT Auditor, because it ensures that the auditor having thorough understanding of financial processes and reporting
- CITP (Certified Information Technology Professional) certification is introduced in 2000 – to demonstrate that a CPA has specialized expertise in IT